RBI tightens cyber oversight of non-bank payment firms

AJINKYA KAWALE
Mumbai, 5 November



At a time when vulnerabilities driven by artificial intelligence are posing challenges to payment systems globally, the Reserve Bank of India (RBI) on Thursday issued a consolidated cybersecurity rulebook for all non-bank payment system operators (PSOs). The rulebook also brings annual system audits and third-party automated teller machine (ATM) switch providers under its ambit.

The revised Master Directions on Cyber Resilience and Digital Payment Security Controls apply to entities including the National Payments Corporation of India, card networks, payment aggregators, prepaid payment instrument issuers and white-label ATM operators (WLAOs), among others.

The directions take effect immediately for large and medium PSOs. Small PSOs have until April 1, 2028, to comply.

PSOs are required to "obtain the source code of all critical applications procured from third-party vendors". Where this is not possible, an escrow arrangement must be in place "to ensure continuity of services", according to the notification.

If a PSO does not own the code, it must obtain a certificate from the developer stating that the application is "free of vulnerabilities, malwares, and any covert channels in the code". A fresh certificate is required after every change.

PSOs must also have "a mechanism to apply them immediately" for critical patches released to address known or reported attacks.

Under the new system audit norms, PSOs must submit an annual audit report within two months of the close of their financial year. For entities following an April-March financial year, this means a deadline of June 1.

LARGE AND MEDIUM PAYMENT OPERATORS MUST COMPLY IMMEDIATELY, WHILE SMALL PAYMENT SYSTEM OPERATORS HAVE UNTIL APRIL 1, 2028

To avoid conflicts of interest, neither the auditor nor its sister concerns must have provided any services to the entity during the preceding two financial years. Auditors must also report any deviation from the process flow submitted by the entity to the RBI while seeking authorisation.

Open observations must be resolved within a "maximum three months".

WLAOs that use shared ATM switch services must contractually require their service providers to comply with cybersecurity controls on an ongoing basis and provide the RBI with access "for on-site/off-site supervision". These controls include disabling remote connections from external machines to the switch network and blocking "potential backdoor connections".

PSOs must also ensure that unregulated entities in their ecosystem, such as payment gateways and vendors, comply with the directions, "subject to mutual agreement".

The rulebook retains the requirements to report cyber incidents — including cyberattacks, outages of critical systems or infrastructure, internal fraud, and settlement delays — to the RBI within six hours of detection. It also retains the requirement to impose a minimum 12-hour cooling-off period after a customer changes their registered mobile number or email address.

The RBI said the consolidation would "provide a single reference point for the entities". Six earlier circulars, the oldest dating back to 2009, have been repealed.